LAB 3 — VF-1D-A-696: Tehdit ve Risk

Çıktı: Risk kaydı (Risk Register).

Operatör istasyonu, olası uzak bakım ve yerel servis üzerinden üç tehdit senaryosu analiz edilmiştir. Senaryolar SF1 (güvenli erişim) ve SF2 (aşırı sıcaklık koruması) ile ilişkilendirilerek L × S × E yöntemiyle önceliklendirilmiştir.

Değerlendirme yöntemi

Her senaryo beş parçadır: Kim → Giriş kapısı → Eylem → Zincir → Fiziksel sonuç.

L istismar edilebilirlik, S fiziksel şiddet, E saldırı yolunun dışa açıklığıdır. Her biri 1–3 aralığındadır; skor L × S × E olarak hesaplanır. Kritik: 18–27; yüksek: 9–17; orta: 4–8; düşük: 1–3. S=3 olanlar S3 bayrağı alır.

Senaryo 1 — Operatör istasyonunda yetkisiz değişiklik

Yetkisini aşan çalışan → SCADA operatör istasyonu → Erişim izniyle ilişkili parametreyi değiştirir → SF1 güvenli sıcaklık/basınç doğrulaması yapamaz → Sıcak yüke erişen çalışan ağır yanık yaşayabilir.

Varsayım: İstasyon fabrika ağından erişilebilir, yazma yetkileri yetersiz ve bağımsız erişim koruması bu değişikliği engelleyemiyor. Kaynaklardaki SCADA görüntüleri tek başına bu yetkilerin varlığını kanıtlamaz.

Puan: L=2, S=3, E=2 → 12 (Yüksek; S3 bayraklı).

L=2: Kullanıcı erişimi ve yetersiz yetki sınırı gerekir. S=3: Sıcak yüke erişim ağır yanığa neden olabilir. E=2: Varsayılan giriş yalnız fabrika ağına açıktır.

Öneri: Operatör ve mühendislik yetkilerini ayırmak; SF1 parametrelerini proses hesabından değiştirilemeyecek biçimde korumak.

Senaryo 2 — Olası uzak bakım yolunun kötüye kullanılması

Fırsatçı dış saldırgan → Varsayılan sürekli açık uzak bakım bağlantısı → Isıtma koruma ayarlarını değiştirir → SF2 aşırı sıcaklığı sınırlayamaz → Tehlikeli ısınma yangına ve ağır yaralanmaya yol açabilir.

Varsayım: Bu bağlantı vardır, internetten sürekli erişilebilir, ele geçirilebilir bir bakım hesabıyla koruma yapılandırmasına ulaşılır ve bağımsız koruma da etkilenir. Bu koşullar VF-1D-A-696 için doğrulanmamıştır.

Puan: L=2, S=3, E=3 → 18 (Kritik; S3 bayraklı).

L=2: Saldırganın bakım hesabını ele geçirmesi gerekir. S=3: Öngörülen koruma kaybı ağır fiziksel sonuç doğurabilir. E=3: Senaryoda dış bağlantı sürekli açıktır.

Öneri: Uzak erişim varsa süreli ve kontrollü yapmak; bakım erişiminin SF2'yi devre dışı bırakamamasını sağlamak.

Senaryo 3 — Yerel mühendislik erişimine müdahale

Tedarik zinciri saldırganı → Makine başındaki servis bilgisayarı → Basınç doğrulama/kilitleme mantığını değiştirir → SF1 basınç güvenli değilken erişim izni verir → Kapak bölgesindeki çalışan ağır yaralanabilir.

Varsayım: Emniyet yapılandırmasına yalnız fiziksel mühendislik bağlantısıyla ulaşılır; saldırganın servis bilgisayarını ele geçirmesi ve değişiklik kontrollerini aşması gerekir. İkinci bağımsız koruma bu zinciri kesemiyor.

Puan: L=1, S=3, E=1 → 3 (Düşük; S3 bayraklı).

L=1: Birden çok kontrolün aşılması gerekir. S=3: Tehlikeli basınç farkında erişim ağır yaralanmaya yol açabilir. E=1: Yapılandırma yalnız makine başında fiziksel erişime açıktır.

Öneri: Servis bilgisayarı ve yapılandırma erişimini korumak; emniyet değişikliklerini onay ve doğrulamaya bağlamak.

Risk tablosu

Senaryo	L	S	E	Skor	Öncelik
2 — Olası uzak bakım	2	3	3	18	Kritik; S3
1 — Operatör istasyonu	2	3	2	12	Yüksek; S3
3 — Yerel servis	1	3	1	3	Düşük; S3

Puanlar belirtilen varsayımlara aittir. Giriş yolu veya koruma yapısı farklıysa ilgili senaryo ve puanlar da değişir.

1. En yüksek öncelikli senaryo hangisi ve neden?

Varsayımsal uzak bakım senaryosu 18 ile en yüksek skora sahiptir. Sürekli dış erişim ve koruma yapılandırmasının değiştirilebilmesi birlikte ağır fiziksel sonuca ulaşmaktadır. Bağlantının gerçek makinede bulunup bulunmadığı ayrıca doğrulanmalıdır.

2. S=3 olup skoru düşük kalan senaryo var mı?

Evet, yerel servis senaryosu. S3 bayrağıyla ayrıca işaretlenir; düşük skora rağmen önlem veya yazılı kabul kararı olmadan kapatılmaz. Bu çalışmadaki bütün senaryolar S3 olarak görünür tutulmuştur.

Kaynaklar

• K1 ve K4 — Test sıcaklığı, basınç ve SCADA bilgileri.

• LAB 1 — Önerilen SF1 ve SF2.

• LAB 2 — Önerilen erişim bölgeleri.

• Genel LAB Föyleri, PDF s. 4; Bootcamp Sunumu, PDF s. 15–18.

• Fatih Özkaynak, Threat & Risk Lab + Safety 4.0 Risk Matrix (LAB3.pdf): PDF s. 11, 23–29 ve 35–37.

Sonuç

Belirtilen erişim varsayımları altında uzak bakım senaryosu en yüksek skoru almıştır. Üç senaryoda da ağır fiziksel sonuç olasılığı nedeniyle S3 bayrağı korunmuş; erişim yetkileri ve emniyet yapılandırmasının korunması önceliklendirilmiştir.